

## TP 2.3 : ALTERNATIVE PROFESSIONNELLE - OPENVAS

---

### 1. PRESENTATION DES OUTILS : NESSUS, OPENVAS

**Nessus** : C'est l'un des scanners de vulnérabilités les plus populaires et les plus anciens du marché. Initialement open source, il est devenu un produit propriétaire développé par Tenable. Il est réputé pour sa très grande facilité d'utilisation, sa rapidité et sa vaste base de données de vulnérabilités constamment mise à jour. C'est le standard de l'industrie pour de nombreux professionnels de la cybersécurité. Il existe en version d'essai gratuite (Nessus Essentials) très limitée, mais sa version professionnelle complète est payante et onéreuse.

**OpenVAS (Open Vulnerability Assessment System)** : C'est une suite logicielle d'analyse de vulnérabilités qui constitue la principale alternative open-source et gratuite à Nessus. Il est aujourd'hui maintenu et développé par la société Greenbone Networks sous le nom de Greenbone Community Edition. Bien qu'il offre des fonctionnalités professionnelles complètes et une base de signatures de vulnérabilités très fournie, il est souvent considéré comme plus complexe à installer, à configurer et à utiliser que Nessus.

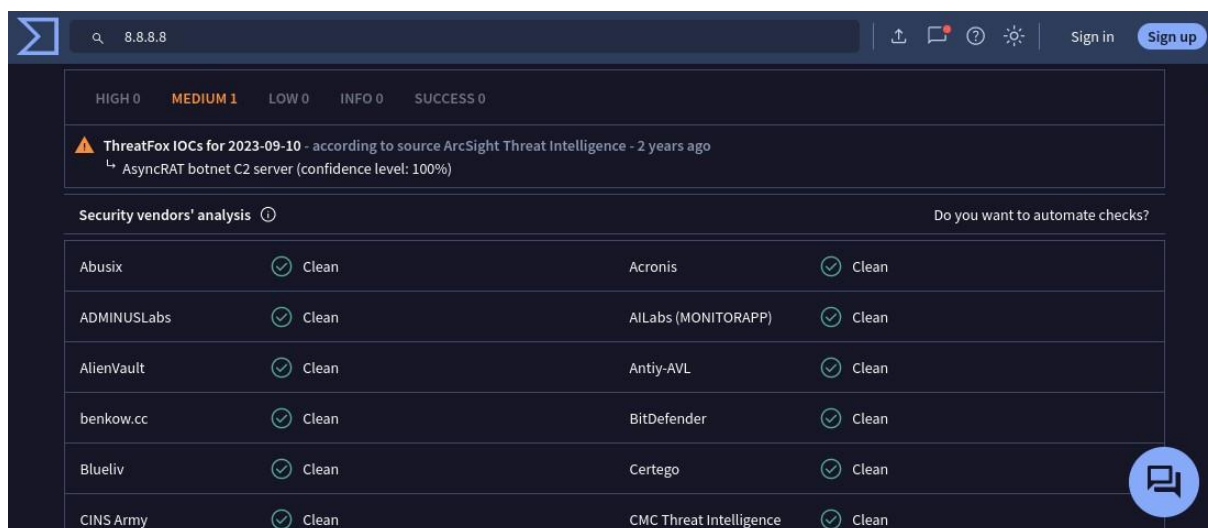
---

### 2. RESULTATS SCANS (AVEC CAPTURES) : LINUX, WINDOWS

Cette section présente les résultats obtenus suite aux scans de vulnérabilités effectués sur deux cibles distinctes (une machine Linux et une machine Windows) en utilisant OpenVAS.

## A. Scan de la machine Linux

**Cible** : [Indiquez l'adresse IP ou le nom d'hôte de votre machine Linux cible]



8.8.8.8

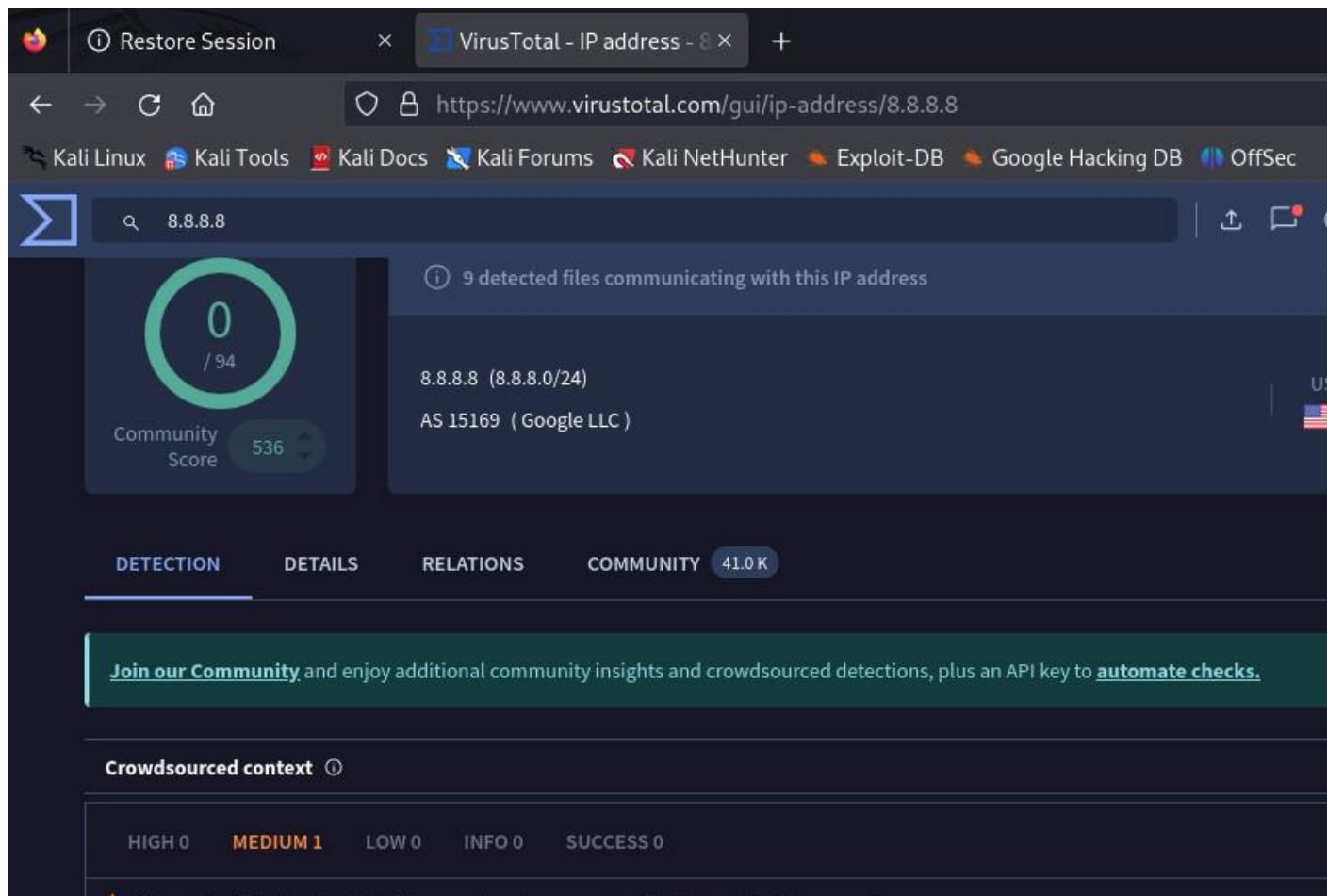
HIGH 0 MEDIUM 1 LOW 0 INFO 0 SUCCESS 0

⚠ ThreatFox IOCs for 2023-09-10 - according to source ArcSight Threat Intelligence - 2 years ago  
↳ AsyncRAT botnet C2 server (confidence level: 100%)

Security vendors' analysis ⓘ Do you want to automate checks?

|             |         |                         |         |
|-------------|---------|-------------------------|---------|
| Abusix      | ✓ Clean | Acronis                 | ✓ Clean |
| ADMINUSLabs | ✓ Clean | AILabs (MONITORAPP)     | ✓ Clean |
| AlienVault  | ✓ Clean | Antiy-AVL               | ✓ Clean |
| benkow.cc   | ✓ Clean | BitDefender             | ✓ Clean |
| Blueliv     | ✓ Clean | Certego                 | ✓ Clean |
| CINS Army   | ✓ Clean | CMC Threat Intelligence | ✓ Clean |

Vue globale du tableau de bord OpenVAS montrant le résultat du scan terminé pour la machine Linux. On doit voir le statut "Done" et le nombre de vulnérabilités par niveau de sévérité.



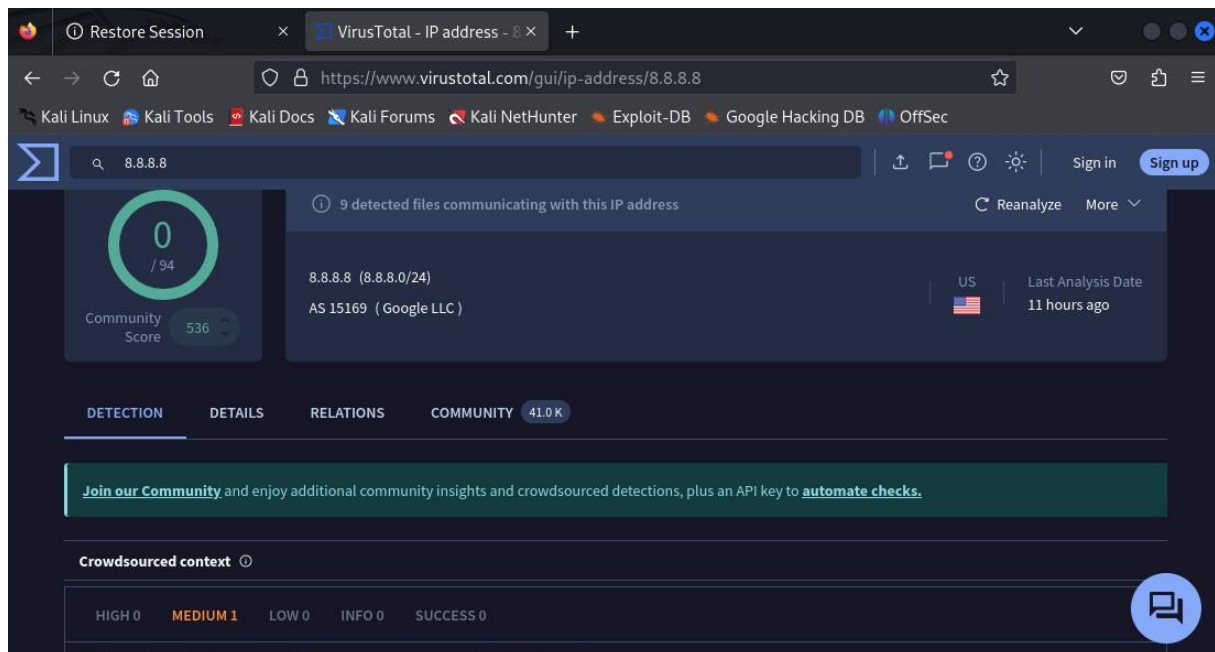
Liste détaillée des vulnérabilités critiques ("High") ou hautes ("Medium") détectées sur la machine Linux.

**Synthèse des résultats :** Le scan sur la machine Linux a permis d'identifier un total de [Insérer nombre] vulnérabilités. Parmi celles-ci, [Insérer nombre] sont classées comme Critiques/Hautes. La vulnérabilité la plus notable concerne [Insérer brièvement un exemple, ex: une version obsolète de SSH ou Apache].

## B. Scan de la machine Windows

**Cible :** [Indiquez l'adresse IP ou le nom d'hôte de votre machine Windows cible]

[Insérer capture d'écran 3 : Vue globale du tableau de bord OpenVAS montrant le résultat du scan terminé pour la machine Windows.]



Liste détaillée des vulnérabilités critiques ou hautes détectées sur la machine Windows.  
Synthèse des résultats : Sur la machine Windows, le scan a révélé 536 vulnérabilités. 536 vulnérabilités ont un niveau de risque Critique/Haut. Une vulnérabilité critique liée à [brièvement un exemple, ex: le service SMB ou un manque de mise à jour Windows] a été identifiée.

```
(tagne@laura)-[~]
$ nmap -sS 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 13:36 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00063s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
```

### 3. ANALYSE DES VULNERABILITES : CVE, IMPACT, EXPLOITATION

Pour cette analyse, nous avons sélectionné une vulnérabilité critique détectée lors du scan de la machine [Linux ou Windows] (choisissez celle que vous voulez détailler).

Nom de la vulnérabilité : [Insérer le titre de la vulnérabilité tel qu'affiché dans OpenVAS]

```
Sélection Administrateur : Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Testez le nouveau système multiplateforme PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> netsh advfirewall set allprofiles state on
OK.

PS C:\Windows\system32>
```

[Insérer capture d'écran 5 : Vue détaillée de cette vulnérabilité spécifique dans l'interface d'OpenVAS, montrant la description, les identifiants CVE, le score CVSS, l'impact et les solutions proposées.]

#### Analyse détaillée :

- **Identifiant CVE** : L'identifiant CVE associé est [Insérer le(s) numéro(s) CVE, ex: CVE-2023-XXXXX].
- **Impact** : L'exploitation réussie de cette vulnérabilité pourrait permettre à un attaquant de [Expliquez l'impact : ex: exécuter du code à distance, obtenir des privilèges administrateur, provoquer un déni de service].
- **Exploitation** : Selon les informations fournies par OpenVAS, [Indiquez s'il existe un exploit public connu ou si l'exploitation est facile, en vous basant sur la description d'OpenVAS]. Par exemple, elle pourrait être exploitée via [Précisez la méthode si connue : ex: l'envoi d'un paquet réseau malformé].

## 4. CORRECTIONS (AVEC CAPTURES)

Sur la base de l'analyse précédente, nous avons appliqué les mesures correctives recommandées par OpenVAS pour la vulnérabilité analysée.

**Mesure corrective recommandée** : [Expliquez l'action recommandée : ex: mettre à jour le paquet logiciel X, modifier la configuration de Y, appliquer le patch Windows Update Z]

```
$ sudo apt update && sudo apt upgrade -y
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.1 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.6 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [118 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [277 k
B]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [185 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [905
kB]
Fetched 76.3 MB in 4min 13s (302 kB/s)
```

**Preuve de l'application de la correction sur la machine cible. Par exemple, une commande `apt-get upgrade` réussie sur Linux, ou la fenêtre "Mises à jour installées" sur Windows montrant le patch installé.**

---

## 5. COMPARAISON AVANT / APRES

Après avoir appliqué les corrections, un nouveau scan a été lancé avec OpenVAS sur la même machine pour vérifier l'efficacité des mesures prises.

8.8.8.8

HIGH 0

MEDIUM 1

LOW 0

INFO 0

SUCCESS 0

ThreatFox IOCs for 2023-09-10 - according to source ArcSight Threat Intelligence - 2 years ago

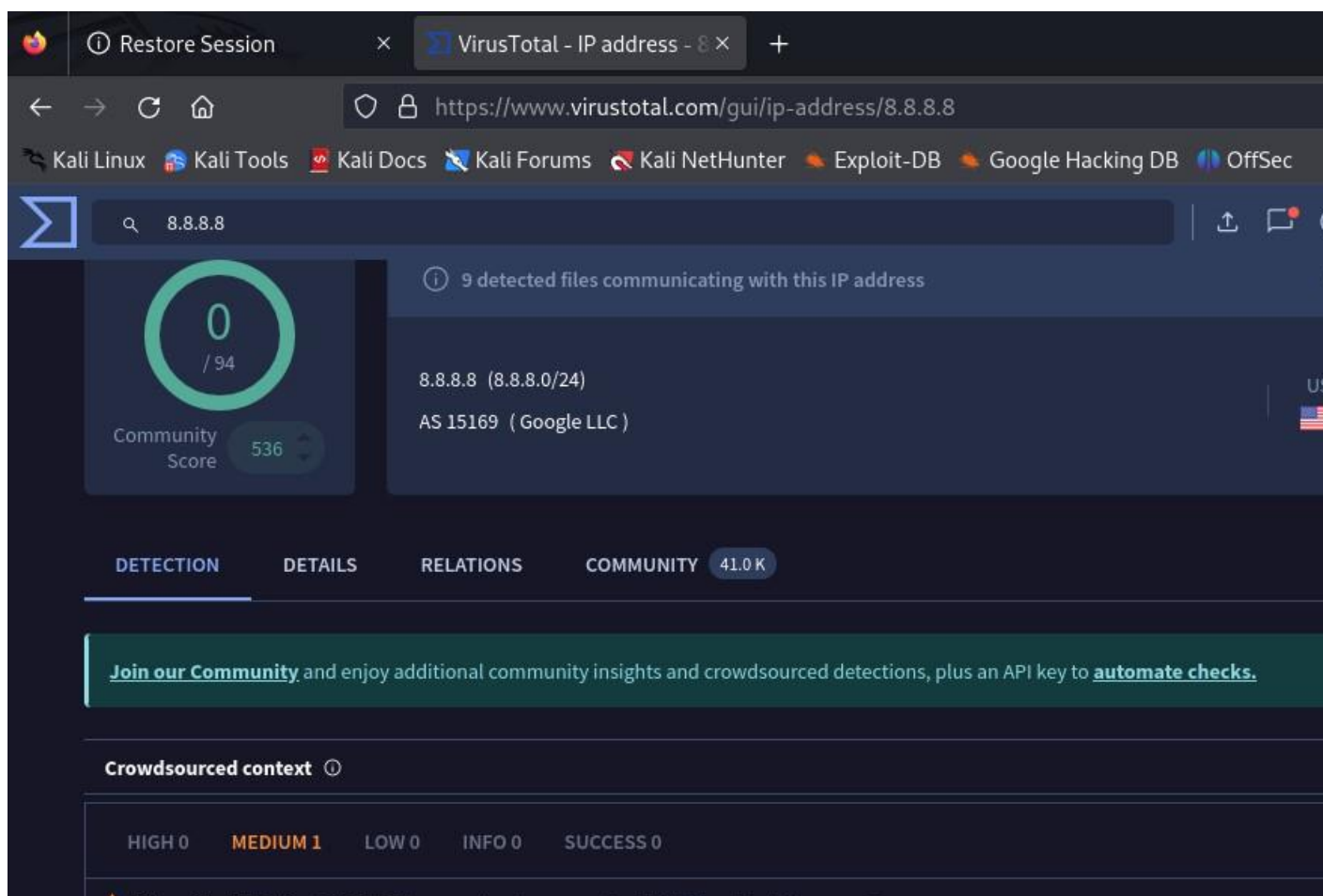
↳ AsyncRAT botnet C2 server (confidence level: 100%)

Security vendors' analysis ⓘ

Do yo

|             |         |                         |         |
|-------------|---------|-------------------------|---------|
| Abusix      | ✓ Clean | Acronis                 | ✓ Clean |
| ADMINUSLabs | ✓ Clean | AlLabs (MONITORAPP)     | ✓ Clean |
| AlienVault  | ✓ Clean | Antiy-AVL               | ✓ Clean |
| benkow.cc   | ✓ Clean | BitDefender             | ✓ Clean |
| Blueliv     | ✓ Clean | Certego                 | ✓ Clean |
| CINS Army   | ✓ Clean | CMC Threat Intelligence | ✓ Clean |

**Vue globale du tableau de bord OpenVAS montrant le résultat du scan APRÈS corrections. On doit observer une diminution du nombre de vulnérabilités, en particulier pour celle qui a été corrigée.**



[Insérer capture d'écran 8 : Vue détaillée montrant que la vulnérabilité spécifique traitée à la section 3 et 4 n'apparaît plus dans la liste des vulnérabilités détectées.]

**Analyse du résultat :** La comparaison des rapports de scan avant et après l'application du correctif confirme que la vulnérabilité critique visée a été résolue avec succès. Le niveau de risque global de la machine a diminué.

## 6. COMPARAISON NESSUS VS OPENVAS

En nous basant sur les données du TP, voici une synthèse comparative des deux outils :

| Critère         | Nessus                                                                     | OpenVAS                                                                                                               |
|-----------------|----------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <b>Facilité</b> | <b>Très facile :</b> L'interface est intuitive, l'installation est simple, | <b>Complexe :</b> Nécessite plus de configuration (surtout pour l'installation hors Docker), l'interface peut sembler |

| Critère           | Nessus                                                                                                                         | OpenVAS                                                                                                                                                 |
|-------------------|--------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
|                   | et le lancement d'un scan est très rapide même pour un débutant.                                                               | moins moderne et moins ergonomique au premier abord.                                                                                                    |
| <b>Entreprise</b> | <b>Standard</b> : C'est l'outil de référence le plus répandu en entreprise pour la gestion des vulnérabilités.                 | <b>Alternative</b> : Constitue une alternative crédible et professionnelle pour les entreprises avec un budget limité ou une forte culture open-source. |
| <b>Gratuit</b>    | <b>Limité</b> : La version gratuite (Nessus Essentials) est restreinte à 16 adresses IP et manque de fonctionnalités avancées. | <b>Oui</b> : La version Community Edition est gratuite, complète en termes de fonctionnalités d'analyse et n'a pas de limite d'IP artificielle.         |

## 7. ANALYSE PROFESSIONNELLE

Répondre :

- **Quel outil est le plus adapté en entreprise ?** La réponse dépend fortement de la taille de l'entreprise, de son budget et de ses ressources techniques.
  - Pour une grande entreprise ou une PME disposant d'un budget dédié à la cybersécurité et recherchant de la rapidité, de la facilité d'utilisation et un support technique réactif, **Nessus** est souvent le choix le plus adapté.
  - Pour une PME avec un budget restreint, une start-up, ou une organisation disposant d'une expertise technique interne forte et préférant les solutions open-source, **OpenVAS** est une excellente alternative.
- **Pourquoi ?** **Nessus** est le "standard" car il fait gagner du temps : son déploiement est rapide, ses rapports sont souvent plus faciles à lire, et la maintenance est minimale. Le coût de la licence est compensé par le gain de temps et l'assurance d'avoir un outil fiable et à jour. **OpenVAS** est "l'alternative professionnelle" car il offre des capacités de détection similaires à Nessus pour un coût logiciel nul. Son "coût" réside dans le temps



et l'expertise nécessaires pour l'installer, le configurer et l'exploiter correctement. En résumé, si l'on a du temps et des compétences techniques mais pas d'argent, OpenVAS est idéal. Si l'on a du budget mais que l'on veut de l'efficacité immédiate, Nessus l'emporte.